SecRAM - Security Risk Assessment Method

Revision 2024-01-25

F. Massacci, K. Labunets, F. Paci

Abstract

The SESAR Security Risk Assessment Methodology (SecRAM) has been designed for use to perform security risk assessment activities in each Operational Focus Areas for Air Traffic Management. The purpose of SecRAM is to provide a repeatable methodology which will allow security risk assessment results from different Operational Focus Areas to be compared.

Having applied the methodology, an assessor for an Operational Focus Area will have achieved the following:

- Identification of their primary assets
- Assessment of the potential impact of a successful attack on the primary assets supported by operational impact scenarios
- Identification of the supporting assets derived from the primary assets
- Identification of the threats targeting the supporting assets
- Identification of the concrete vulnerabilities allowing the realization of the threats
- Risk level evaluation of the threat scenarios targeting the supporting assets based on the likelihood and the impact of those threat scenarios
- List of additional controls to be observed to address security and safety risks

This document provides a simplified version of the methodology to be used in an educational setting.

1 Table of Contents

1.1 Table of Contents

1 TABLE OF CONTENTS **2**
1.1 TABLE OF CONTENTS 2
1.2 2
1.3 LIST OF TABLES 2
2 INTRODUCTION **2**
2.1 PURPOSE OF THE DOCUMENT 2
2.2 LIMITATIONS 3
2.3 INTELLECTUAL PROPERTY RIGHTS 3
3 GLOSSARY OF TERMS **3**
3.1 ACRONYMS AND TERMINOLOGY 4
4 SECRAM OVERVIEW **4**
5 RISK IDENTIFICATION **5**
5.1 ASSET IDENTIFICATION & VALUATION 5
5.1.1 Primary asset identification & Impact Assessment *6*
5.1.2 Supporting asset valuation *8*
5.2 THREAT SCENARIO 8
6 RISK EVALUATION **10**
6.1 IMPACT EVALUATION 10
6.2 LIKELIHOOD EVALUATION 11
6.3 RISK LEVEL EVALUATION 13
7 RISK TREATMENT **13**
8 REFERENCES **15**

1.2

1.3 List of Tables

Table 1 - Definitions of Frequently Used Terms 4
Table 2 - Definition of Acronyms 4
Table 3 - SecRAM Impact Areas 7
Table 4 - Likelihood Definition 11
Table 5 - Threat Likelihood Areas 11
Table 6 - Risk Level Calculation 12
Table 7 - Threat List 15

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

2 Introduction

2.1 Purpose of the document

The document provides the risk assessment methodology to be used by the Operational Focus Areas (OFAs) of the Single European Sky Air Traffic Management Research (SESAR) to assess the risk levels associated with the area. It has been adapted and simplified to be used as a reference material for a University course by lecturers from the University of Trento and the Vrije Universiteit Amsterdam.

The methodology described in this document is compatible with both the framework described within the EUROCONTROL Security Risk Management Toolkit (SRMT) [2,3], with ISO 27005:2022 [4] and NIST 800-30:2012 [5]. Other standards and regulations such as ISO/IEC 31000:2018 [6] and Commission Implementing Regulation (EU) No 1035/2011 [7] have also been considered in this document.

2.2 Limitations

As defined by ISO 27005:2022 [4], the security risk assessment methodology starts with risk identification and ends with risk evaluation including risk treatment.

This methodology does not include the following processes:

- A threat detailed assessment process
- A vulnerability detailed assessment process
- Extension of the primary asset criteria (non-repudiation, accountability...)

2.3 Intellectual Property Rights

This document consists of a simplified and modified version of SJU foreground as SESAR Project Number 16.02.03, D02-003 Edition 00.01.05, “SESAR ATM Security Risk Assessment Method” [1]. This material can only be used for educational purposes by the students enrolled in the Cyber Security Risk Assessment Course at the University of Trento and Vrije Universiteit Amsterdam. All other uses prohibited.

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

3 Glossary of terms

Table 1 - Definitions of Frequently Used Terms

Term	Definition
Asset	Elements in the system that have value for the achievement of business objectives
Availability	The property of being accessible and usable upon demand by an authorized entity
Compromised	The loss, corruption or reduction in the performance of a primary or supporting asset (e.g loss of confidentiality, reduced availability, increased latency, corruption of data)
Confidentiality	The property that information is not made available or disclosed to unauthorized individuals, entities, or processes
Control	Means of managing risk, including policies, procedures, guidelines, practices or organizational structures, which can be administrative, technical, management, or legal in nature
Impact	The extent to which compromising confidentiality, availability or integrity of an asset affects the achievement of business objectives
Impact Scenario	A sequence of operational steps describing the impact done over a primary asset (see fig 2)
Integrity	The property of safeguarding the accuracy and completeness of assets
Likelihood	Evaluation of the chance of a threat scenario successfully occurring
Primary Asset	Intangible function, service, process or information that are part of the ATM system within the scope of the project and has value to the system
Risk	The potential that a given threat will exploit vulnerabilities of an asset or group of assets and thereby have an impact on the identified assets.
Risk assessment	The overall process of risk identification and risk evaluation
Risk evaluation	The process of assigning values to the likelihood and impacts of a risk
Risk identification	The process of finding, listing and characterizing elements of risk
Risk treatment	The process of selecting and implementing measures to modify risk
Security registers	The set of security data and information shared among all projects subjects to the risk assessment
Supporting Asset	Supporting assets are entities which enable the primary assets. Supporting assets possess the vulnerabilities that are exploitable by threats aiming to impair primary assets.
Threat	The potential cause of an unwanted incident which may result in an impact on the operational area object of the risk assessment
Threat Scenario	A threat scenario is a combination of a threat over a supporting asset within the considered environment (see)
Vulnerability	A security weakness of an asset that can be exploited by an attacker via a threat

3.1 Acronyms and Terminology

Table 2 - Definition of Acronyms

Term	Definition
ATM	Air Traffic Management
CIA	Confidentiality, Integrity, Availability
E-ATMS	European Air Traffic Management System
MSSC	Minimum Set of Security Controls
OFA	Operational Focus Area – It is an area of operation which must be subject to a risk assessment.
SecRAM	Security Risk Assessment Methodology
SESAR	Single European Sky ATM Research
SESAR Programme	The programme which defines the Research and Development activities and Projects for the SJU.
SJU	SESAR Joint Undertaking (Agency of the European Commission)
SJU Work Programme	The programme which addresses all activities of the SESAR Joint Undertaking Agency.
WP	Work Package

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

4 SecRAM overview

This methodology is part of an overall SESAR risk management system described in the ATM Security Reference Material [1]. It has been adapted by the University of Trento and Vrije Universiteit Amsterdam for use in the courses for Security and Safety Risk Assessment.

The methodology consists of the following steps:

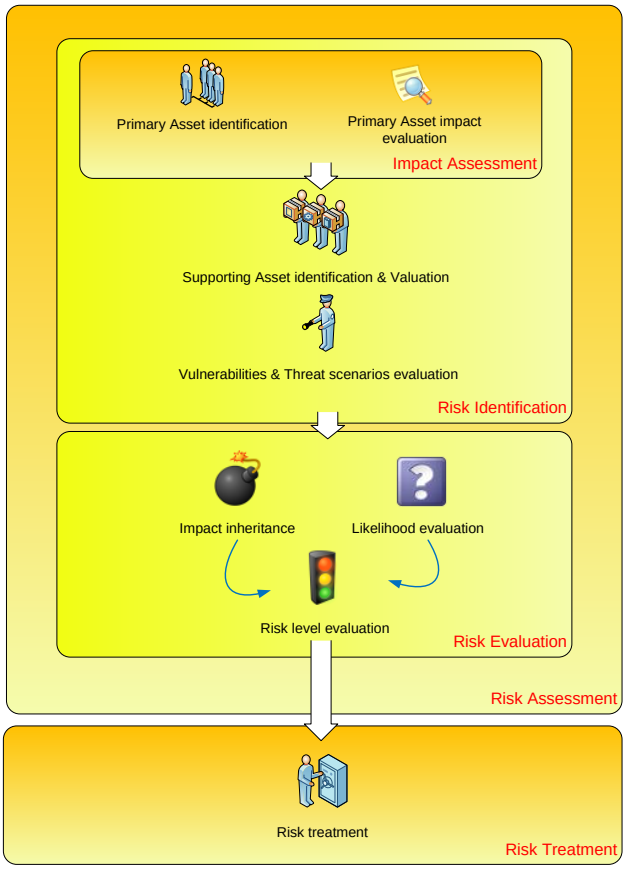
Impact Assessment:

- Identification of their primary assets
- Assessment of the potential impact of a successful attack on the primary assets supported by operational impact scenarios

Risk Assessment:

- Identification of the supporting assets derived from the primary assets
- Identification of the threats targeting the supporting assets
- Identification of the Vulnerabilities allowing the realizations of those threats
- Establishment of a risk evaluated classification of the threat scenarios targeting the supporting assets based on the likelihood and the impact of those threat scenarios
- Establishment of a list of additional controls to be achieved to address security risks

The risk assessment as defined in ISO 27005:2022 [4] ends with the risk level evaluation of the threat scenario.



This document adds a brief description of risk treatment to the steps of the methodology:

Risk Treatment:

- Selecting management options to address identified risks and iteratively calculate the residual risk

Following the steps in the methodology results in the information described above being captured in a table.

In order for the security risk assessments to be comparable and repeatable throughout different focus areas, the application of the methodology across several should use the following principles:

- The classification schemes (CIA criteria, likelihood, impact and risk) are used by all OFAs
- The assets identified and evaluated by each OFA should be shared via Security Registers across the organizations in order to have a consistent definition and evaluation of shared assets.

The initial steps also provide information for the shared Security Registers that is omitted in this document, since it has been reduced to use in an educational setting where a single OFA is typically analyzed.

> ***Example:*** Throughout this document, a simple example will illustrate the steps of the methodology. The example will assess the security risks of SESAR OFA X, an imaginary, simplified OFA which has been identified as requiring a full risk assessment. Boxes similar to this one will document the evolution of the OFA X security risk assessment.

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

5 Risk identification

In Chapter 5.1, assets are identified, classified and evaluated. In Chapter 5.2, the vulnerabilities and threats associated with the assets are identified in order to build the threat scenario.

5.1 Asset identification & valuation

The methodology focuses on two types of assets: primary assets and supporting assets.

Primary assets are intangible, for example, information and services which are of value to the OFA and which the OFA wants to protect, such as always keeping separation between aircrafts to avoid crashes. A successful attack would ultimately impair the primary assets and have an impact on the ATM system.

Supporting (or tangible) assets are entities which enable the primary assets. Supporting assets possess the vulnerabilities that are exploitable by threats aiming to impair primary assets.

Note: *primary asset information is not to be confused with the entity containing the information, which is the supporting asset. Primary assets are intangible. For example, if a primary asset is specific, sensitive information then the supporting asset could be the hard disk on which the information resides.*

A scenario that describes how compromising the CIA of a primary asset can have an impact is called an **Impact Scenario**. A scenario that describes how a threat exploits a vulnerability of a supporting asset to have an impact on a primary asset is called a **Threat Scenario**.

Section §5.1.1 gives some examples of primary assets and the scheme for primary asset evaluation. Section §5.1.2 does the same for supporting assets.

Note: *It is often useful to consider the assets as a tree of primary assets and/or supporting assets, with the primary assets obviously standing higher in the hierarchy than the supporting assets. For this view to be consistent with the methodology, just consider the lowest level of primary assets to be the set of primary assets evaluated in the following chapters. The same applies to the supporting assets: one has to consider the lowest set of supporting assets that are reasonably compatible with the threats that will be applied to them.*

5.1.1 Primary asset identification & Impact Assessment

Primary assets are of two types:

Services addressed by the OFA, system services, operational concepts and activities, for example:

- Services whose loss or degradation make it impossible to carry out the business mission of the OFA
- Services that contain secret processes or processes involving proprietary technology
- Services that, if modified, can greatly affect the accomplishment of the OFA's mission
- Services that are necessary for the OFA to comply with contractual, legal or regulatory Requirements

Information and more generally, primary information mainly comprises:

- Vital information for the exercise of the OFA's mission or business
- Personal information, as can be defined specifically in the sense of the national laws regarding privacy
- Strategic or confidential information required for achieving objectives determined by the strategic orientations or identified as confidential by an authority.
- High-cost information whose gathering, storage, processing and transmission require a long time and/or involve a high acquisition cost

For each primary asset evaluated, an OFA must assess the level of Confidentiality (C), Integrity (I) and Availability (A) required. This evaluation is a number from 1 to 5 for each of the CIA criteria allocated to each primary asset.

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

Note: *Only CIA criteria are considered in this methodology. For most OFAs this should be enough to express the security needs on the primary assets. Other criteria can be found in risk assessment methodologies like, non-repudiation, traceability, provability. Those could arguably be considered as a combination of CIA needs or considered as objectives rather than security needs.*

To obtain this evaluation, the OFA must evaluate the impact due to loss or degradation of Confidentiality (C), Integrity (I) and Availability (A) for each of its primary assets and on each of the SESAR Security Impact Areas described by the following table. Comparison shall not be done between impact areas, each area should be evaluated independently:

Table 3 - SecRAM Impact Areas

	IMPACT LEVELS				
IMPACT AREAS	**1. No impact, NA**	**2. Minor**	**3. Severe**	**4. Critical**	**5. Catastrophic**
IA1:PERSONNEL	No injuries	Minor injuries	Severe injuries	Multiple Severe injuries	Fatalities
IA2:CAPACITY	No capacity loss	Loss of up to 10% capacity	Loss of 30%-10% capacity	Loss of 60%-30% capacity	Loss of 60%-100% capacity
IA3:PERFORMANCE	No quality abuse	Minor system quality abuse	Severe quality abuse that makes systems partially inoperable	Major quality abuse that makes major system inoperable	Major quality abuse that makes multiple major systems inoperable
IA4:ECONOMIC	No effect	Minor loss of income	Large loss of income	Serious loss of income	Bankruptcy or loss of all income
IA5:BRANDING	No impact	Minor complaints	Complaints and local attention	National attention	Government & international attention
IA6:REGULATORY	No impact	Minor regulatory infraction	Multiple minor regulatory infractions	Major regulatory infraction	Multiple major regulatory infractions
IA7:ENVIRONMENT	Insignificant	Short Term impact on environment	Severe pollution with noticeable impact on environment	Severe pollution with long term impact on environment	Widespread or catastrophic impact on environment

Each of the impact evaluations with a value greater than 1 must be associated with an impact scenario as a rationale of the given impact.

The final C, I and A values for each primary asset will be the **maximum impact level** from this evaluation. Other alternatives might be used in a specific risk assessment (e.g. weighted) that might be specific for the OFA or the applicable domain.

Note: *In the context of SecRAM, the Security Impact Areas are limited to those listed in Table 1. The different impact areas are defined to cover all relevant impacts due to the loss of CIA. OFAs may also consider the examples of effects on safety of operation provided by ESARR 4 [9] or any other domain specific impact areas. For example, the use of SecRAM for a national security risk assessment might replace regulatory impact with political impact.*

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

Example: In the example we will consider the SESAR OFA X which has 3 primary assets. Note that primary assets are high level, intangible, important functions, information or services used by the OFA. We will call these primary assets PA#1, PA#2 and PA#3. It could for example be functions like "Provide ATC trajectories to Aircraft", "Send messages and alert to the crew" or information like "Passenger list" or "Meteorological data" (in that case the primary asset is the intangible data, not the media containing it). We will consider the following CIA for the 3 primary assets, based on the CIA impact table above:

	IA1	IA2	IA3	…	…	IA7	Overall impact
PA#1 Compromise of C	2	1	1	…	…	1	2
PA#1 Compromise of I	1	4	1	…	…	1	4
PA#1 Compromise of A	2	2	1	…	…	4	4
PA#2 Compromise of C	1	1	1	…	…	1	1
PA#2 Compromise of I	1	1	1	…	…	1	1
PA#2 Compromise of A	2	2	1	…	…	3	3
PA#3 Compromise of C	1	1	2	…	…	1	2
PA#3 Compromise of I	1	1	2	…	…	1	2
PA#3 Compromise of A	1	1	1	…	…	1	1

The second line, for example, could be read as: "If an attacker was able to modify PA#1 integrity (Provide ATC trajectories to Aircraft) then we could have a loss of major SESAR systems (S2)". This statement should be backed up with an operational scenario explaining this impact.

This table can therefore be summarized as follows:

	C	I	A
PA#1	2	4	4
PA#2	1	1	3
PA#3	2	2	1

▪

5.1.2 Supporting asset valuation

The supporting assets are those which possess the vulnerabilities that are exploitable by threats aiming to impair the primary assets within scope. They are of various types, including for example, hardware, software, operating systems, business applications, networks, storage media, relays, communication interfaces, personnel, sites, premises, utilities, subcontractors, authorities, and other organizations.

Every supporting asset must be linked to the primary assets that it is supporting and viceversa.

- If a supporting asset is not linked with any primary asset, an OFA may have missed a primary asset and OFA must answer the question "*Why is that supporting asset important to me?*".
- Conversely, if a primary asset is not linked to any supporting asset, the OFA must answer the question "*How am I fulfilling the function described by that primary asset if no supporting asset has been found?*".

At the end of this step, all primary assets shall be linked with at least one supporting asset, and all supporting assets shall be linked with at least one primary asset. This is enough to evaluate the supporting assets. ***Supporting assets will inherit the CIA level of the primary assets they support***, as we will see in section 5.2.

Example: We will consider that OFA X has 4 supporting assets:

- An engineering workstation: a laptop that is used to bring relevant software functionality and data from place to place (eg maintenance)
- A network: that is used to communicate software data
- A radar: that is used to gather relevant radar information
- A communication means: that is used by the operators to talk to each other

We will consider the following link between the primary and supporting assets:

	PA#1	PA#2	PA#3

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.
This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

Engineering workstation	X		X
Network	X		
Radar			X
Communication means	X	X	X

This means, for example, that the mobile device has no impact on PA#2 and that the communication means impacts all of the primary assets of OFA X.

The supporting assets will therefore inherit the CIA value of their associated primary assets.

5.2 Threat scenario

The objective of this chapter is to obtain the list of threat scenarios relevant for the OFA.

A **threat** is a combination of an attacker with own resources, motivation and goal, regardless of the existing security measures or vulnerabilities existing in the OFA. The threat is the potential cause of an unwanted incident which may result in an impact on the OFA.

A **vulnerability** is a security weakness of an asset that can be exploited by an attacker via a threat.

The full process would require a vulnerability assessment of the supporting assets and a threat assessment of the OFA to be carried out in detail. This methodology has been reduced to a class setting and therefore does not deal in detail with the vulnerability assessment and the threat assessment of the OFA. Those tasks are dependent on the type of supporting asset being evaluated.

In this methodology, a threat scenario is a combination of a threat with identified vulnerabilities leading to the Inherited Impact level and the Reviewed Impact (RI) level. The **threat scenario** list is built as follows:

For each supporting asset (only supporting assets have vulnerabilities):

- Identify relevant threats (a sample threat list is given in APPENDIX A)
- Identify relevant vulnerabilities that can be exploited by an attacker.
- For each threat, identify the targeted criteria (Confidentiality, Integrity and Availability)

With this data, we build a table combining the threats for every supporting asset, and with the target criteria on CIA, we know how the primary assets are impacted.

Example: having parsed the threat catalogue for each supporting assets, we will consider the following :

- The engineering workstation is vulnerable to theft, malicious code insertion and vandalism.
- The network is vulnerable to eavesdropping, and possibly vandalism
- The radar is only vulnerable to the jamming threat.
- The communication means is only vulnerable to the eavesdropping threat.

These decisions are only for the sake of keeping the example simple. We could explain in the analysis of the system, for example, that the network is managed by a subcontractor which might provide security guards to prevent vandalism on the network; and that the radar, after application of a set of default minimal physical security control [2], is only vulnerable to jamming.

In our context, the threats considered have the following CIA targets:

- Theft targets C and A
- Malicious code targets C and I
- Vandalism targets I and A
- Jamming targets I and A

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

- Eavesdropping targets C only.

We can build the following threat scenario table, which summarizes all information above:

Supporting assets	Threats	Vulnerabilities	Primary assets								
			PA#1			PA#2			PA#3		
			C	I	A	C	I	A	C	I	A
			2	4	4	1	1	3	2	2	1
Engineering Workstation	Theft	Individual user careless with his device	X		X				X		X
	Malicious code	Code downloadable by all users visiting a site with a vulnerable operating system	X	X					X	X	
	Vandalism	Individual user careless with his device		X	X					X	X
Network	Eavesdropping	Use of public network	X								
	Vandalism	Network routers are in a public location			X						
Radar	Jamming	Accessible from a public road								X	X
Communication means	Eavesdropping	Communication over the air network without encryption	X			X			X		

Each row of this table corresponds to a direct threat scenario targeting a supporting asset. For example, the first row can be read as: "Individual user is careless with his device and it is stolen therefore both the confidentiality and availability of the information of PA#1 and PA#3 are in jeopardy."

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

6 Risk evaluation

A **threat scenario** has a specific likelihood of occurrence and will have a specific Inherited and Reviewed Impact. The combination of Likelihood and Reviewed Impact of a threat scenario is a risk for the OFA evaluated here.

6.1 Impact evaluation

The impact of a threat scenario is evaluated at two levels:

- The **Inherited Impact**: this is the automatic impact gathered from the previous information of the threat scenario table. The Inherited Impact is linked to an impact scenario described during the Impact Assessment phase (§5.1.2). The threat scenarios target the primary assets evaluated on the CIA criteria. By taking the maximum impact of all those targeted criteria, we get the Inherited Impact.
- The **Reviewed Impact** (RI): exceptionally, it may happen that the specific threat scenario does not "activate" the worst impact that was anticipated during the impact assessment phase. In that case, the Reviewed Impact reflects a less important impact that is associated with the threat. Such difference must be thoroughly justified

Therefore, the Reviewed Impact is always equal to or less than the Inherited impact. If the considered threat scenario can effectively produce the anticipated impact, then Reviewed Impact is the same as Inherited Impact. When the Reviewed Impact is different from the Inherited Impact, it must be justified by the asset owner or the assessor.

The Inherited Impact will not be used further in the methodology. Only the Reviewed Impact is kept in the rest of the risk assessment. If the changes Reviewed Impact is unclear in your context, just consider the Reviewed Impact to be equal to the automatically calculated Inherited Impact.

Example: The Inherited Impact level is automatically deduced from the previous data. Most of the time, it will be the same as the Reviewed Impact. In our example, we obtain the following table:

Supporting assets	Threats	Vulnerabilities	Primary assets									Inherited Impact	Reviewed Impact
			PA#1			PA#2			PA#3				
			C	I	A	C	I	A	C	I	A		
			2	4	4	1	1	3	2	2	1		
Engineering Workstation	Theft	Individual user careless with his device	X		X				X		X	4	4
	Malicious code	Code downloadable by all users visiting a site with vulnerable operating system	X	X					X	X		4	4
	Vandalism	Individual user careless with his device		X	X					X	X	4	3
Network	Eavesdropping	Use of public network	X									2	2
	Vandalism	Network routers are in a public location			X							4	4
Radar	Jamming	Accessible from a public road								X	X	2	2
Communication means	Eavesdropping	Communication over the air network without encryption	X			X			X			2	1

Here we can see that all but 2 threat scenarios have the same Inherited and Reviewed Impacts. For, these two (Vandalism on Mobile device and Eavesdropping on Communication means) the impact has been reduced and this must be justified by the asset owner or the assessor.

6.2 Likelihood evaluation

The likelihood is the evaluation of the chance of a threat scenario successfully occurring, considering the **existing** security countermeasures and **existing** security controls (Such as the minimal default set of controls)

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

The likelihood of a threat scenario is a number from 1 (improbable) to 5 (frequent or certain), with the following qualitative definition:

Table 4 - Likelihood Definition

Likelihood	Qualitative interpretation
5. Certain	There is a high chance that the scenario successfully occurs in the short term.
4. Very likely	There is a high chance that the scenario successfully occurs in the medium term.
3. Likely	There is a high chance that the scenario successfully occurs during the OFA lifetime.
2. Unlikely	There is a low chance that the scenario successfully occurs during the OFA lifetime.
1. Very Unlikely	There is very little or no chance that the scenario successfully occurs during the OFA lifetime

The OFA can take the following parameters into consideration before deciding on the likelihood of a threat scenario. The list is not exhaustive and other parameters could be used to explain the choice of selection of the likelihood level.

- **Elapsed time:** time needed to prepare the attack, including the research of information, exploitation, analysis of the difficulty to successfully conduct it, development of dedicated malicious software, etc.
- **Expertise:** skills required to successfully achieve the attack.
- **Knowledge of the target of risk analysis:** knowledge of the target, may be on design, implementation, operational procedures, vulnerabilities and weaknesses, etc.
- **Equipment:** equipment (either software, hardware, personnel or monetary resources) required to be able to perform the attack
- **Feeling of Impunity:** represents the assessment by the attacker of the likelihood of being identified during the attack (accountability) and the sanctions to which he may be subjected
- **Window of opportunity:** time period during which the target is accessible by an attacker
- **Attractiveness of the target:** the potential revenues or interest that the attacker could gain from achieving the attack

For example, the more an attacker needs expertise and time to prepare and actually perform the threat scenario, the less likely it is that this threat scenario will successfully occur.

Table 5 - Threat Likelihood Areas

	THREAT LIKELIHOOD LEVELS				
THREAT LIKELIHOOD AREAS	**1. Not Credible (Very Unlikely)**	**2. Remote (Unlikely)**	**3. Occasional (Likely)**	**4. Probable (Very Likely)**	**5. Frequent (Certain)**
LA1: SKILLS	Inside information	Expert knowledge	Specialist knowledge	Engineering knowledge	No limitation
LA2: MEANS	Extremely scarse	Hard to obtain	Available with difficulty	Publicly available	No limitation
LA3: OPPORTUNITY	Never	Seldom	Regularly	Frequently	Always
LA4: PROFIT	None	Little	Fair	Significant	Large
LA5: ATTENTION	No media attention	Little attention of local media	Fair attention of local media	Regional media attention	World-wide media attention
LA6: IMPUNITY	Certainty of punishment	High chance of punishment	Fair chance of punishment	Little chance of punishment	No chance of punishment
LA7: DETECTION	Certainty of detection	High chance of detection	Fair chance of detection	Detection due to 'chance'	Not possible to predict or detect

The likelihood could also be based on evidence gathered on existing systems that are comparable to those of the OFA. This methodology does not provide automatic calculation means to evaluate the likelihood from the listed parameters. However, the OFA shall be able to provide a rationale for the likelihood it has selected.

Example: Using the likelihood scheme described in this chapter, we obtain the following table (the primary assets column and the Inherited Impact column have been omitted for readability):

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

Supporting assets	Threats	Vulnerabilities	Reviewed Impact	Likelihood
Mobile device	Theft	Individual user careless with his device	4	1
	Malicious code	Code downloadable by all users visiting a site with wrong operating system	4	5
	Vandalism	Individual user careless with his device	3	3
Network	Eavesdropping	Use of public network	2	3
	Vandalism	Network routers are in a public location	4	2
Radar	Jamming	Accessible from a public road	2	4
Communication means	Eavesdropping	Communication over the air network without encryption	1	3

6.3 Risk level evaluation

The risk level is the overall risk that a threat scenario represents, considering its likelihood and potential impact. The calculation of the risk level for a given threat scenario is automatically deduced from the Reviewed Impact, the likelihood and the following matrix:

Table 6 - Risk Level Calculation

	Reviewed Impact				
Likelihood	1. No impact, NA	2. Minor	3. Severe	4. Critical	5. Catastrophic
5. Certain	Low	High	High	High	High
4. Very likely	Low	Medium	High	High	High
3. Likely	Low	Low	Medium	High	High
2. Unlikely	Low	Low	Low	Medium	High
1. Very Unlikely	Low	Low	Low	Medium	Medium

For example, a threat scenario with a Reviewed Impact level of 4 and a likelihood of 3 is considered as a High risk level. The meaning of Low, Medium and High risk levels is given in chapter 5.

Such a table depends on the risk appetite of the particular customer organization which is contracting the risk (in our example case the SESAR Joint Undertaking). However, in order to make risk assessment repeatable and comparable such a Table must **not** be changed across OFAs or across risk assessments. If such change is deemed necessary then all past and still relevant risk assessment should be re-evaluated with the new table.

Example: The risk level is automatically deduced from the previous data and the risk level table of this chapter:

Supporting assets	Threats	Vulnerabilities	Reviewed Impact	Likelihood	Risk levels
Engineering Workstation	Theft	Individual user careless with his device	4	1	Medium
	Malicious code	Code downloadable by all users visiting a site with wrong operating system	4	5	High
	Vandalism	Individual user careless with his device	3	3	Medium
Network	Eavesdropping	Use of public network	2	3	Low
	Vandalism	Network routers are in a public location	4	2	Medium
Radar	Jamming	Accessible from a public road	2	4	Medium
Communication	Eavesdropping	Communication over the air network without encryption	1	3	Low

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

7 Risk treatment

The risk assessment as defined by ISO 27005:2022 [4] ends at the risk evaluation step which is the previous chapter. However, in this chapter we briefly describe risk treatment along NIST 800-53 [11]..

There are four options available for each threat scenario. Regarding each threat scenario, a OFA can:

- **Accept (or Tolerate)** the risk, which means that no further action is needed. The risk level is considered low enough to be accepted.
- **Reduce (or Treat)** the risk to a new level through the selection of controls so that the residual risk can be reassessed as being acceptable. Several standards offer such lists of controls [10,11]. These additional controls shall be provided as an output of this risk treatment phase.
- **Avoid (or Terminate)** the risk, which means that if the risk is considered too high and the counter-measures to reduce it too costly, then the OFA can decide to withdraw the activity or change its nature so that the risk is not present anymore.
- **Transfer** the risk, which means that the OFA decides that the risk should be transferred to another party that can most effectively manage the particular risk.

The risk treatment decision has to be managed at architecture level to ensure consistency of security solutions.

Risk treatment options shall be decided regarding the risk level of a threat scenario:

- Risk is Low: the OFA can decide by itself what risk treatment is best for its interests. This decision shall be properly rationalized.
- Risk is Medium: the OFA has to validate with the other involved OFAs and OFAs what treatment should be applied.
- Risk is High: the OFA has to validate with key business decision makers what treatment should be applied.

For each suggested treatment a new assessment of the risk consequential to the deployment of the mitigation should be specified. In particular it should provide a rationale on whether the proposed mitigation implies a

- **Reduction in Impact**: so that the proposed mitigation measures reduce the impact on the primary assets in case the threat scenario should happen.
- **Reduction in Likelihood**: so that the proposed mitigation measures reduce the chances of the threat agent being able to actually bring the threat scenario to happen.

Example: In the resulting risk table below all low risks are accepted and linked to the existing controls and counter-measures that motivate that decision

Supporting assets	Threats	Vulnerabilities	Reviewed Impact	Likelihood	Risk levels
Engineering Workstation	Theft	Individual user careless with his device	4	1	Medium
	Malicious code	Code downloadable by all users visiting a site with wrong operating system	4	5	High
	Vandalism	Individual user careless with his device	3	3	Medium
Network	Eavesdropping	Use of public network	2	3	Low
	Vandalism	Network routers are in a public location	4	2	Medium
Radar	Jamming	Accessible from a public road	2	4	Medium
Communication means	Eavesdropping	Communication over the air network without encryption	1	3	Low

The vandalism threat on the engineering workstation is transferred to the team responsible for material hardening in another OFA. The “higher” OFA validated that decision and ensured that it was taken into account in the other OFA.

The vandalism threat on the network was reduced by deciding to apply additional physical security controls. The “higher” OFA validated that this was enough to accept the residual risk.

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

The malicious code risk is reduced by applying additional mobile device security controls. The key decision makers validated that decision and ensured that those controls were consistent in all OFAs needing this kind of controls.

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

8 References

[1] 16.06.02 D06 ATMSecReferenceMaterial 00.01.00

[2] SESAR JU. SecRAM 2.0. Security Risk Assessment methodology for SESAR 2020, 2017

[3] EUROCONTROL ATM Security Risk Management Toolkit – Guidance material v1.0

[4] ISO/IEC 27005:2022, Information security, cybersecurity and privacy protection Guidance on managing information security risks

[5] NIST SP 800-30 Rev. 1, Guide for Conducting Risk Assessments, 2012

[6] ISO/IEC 31000:2018 - Risk Management

[7] Commission Implementation Regulation (EU) No 1035/2011, laying down common requirements for the provision of air navigation services, 17th October 2011

[8] M. Giacalone et al. Security triage: an industrial case study on the effectiveness of a lean methodology to identify security requirements. ESEM 2014

[9] EUROCONTROL, ESARR 4 – Risk Assessment and Mitigation in ATM, 2001

[10] IT-Grundschutz-Kataloge (Threat Baseline Protection Catalogs) from the German Federal Office for Security in Information Technology (BSI) – In English

[11] NIST SP 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.

Appendix A

Applicable threats are not limited to the ones described in this appendix. This is just a sample threat list of deliberate actions extracted from ISO 27005. Additional threats can be found in BSI [8]

Table 7 - Threat List

Loss Type	Threat Description
Physical damage	Fire
	Water damage
	Pollution
	Major accident
	Destruction of equipment or media
	Dust, corrosion, freezing
Loss of essential services	Failure of air-conditioning or water supply system
	Loss of power supply
	Failure of telecommunication equipment
Disturbance due to radiation	Electromagnetic radiation
	Thermal radiation
	Electromagnetic pulses
Compromise of information	Interception of compromising interference signals
	Remote spying
	Eavesdropping
	Theft of media or documents
	Theft of equipment
	Retrieval of recycled or discarded media
	Disclosure
	Data from untrustworthy sources
	Tampering with hardware
	Tampering with software
	Position detection
Technical failure	Saturation of the information system
	Breach of information system maintainability
Unauthorized action	Unauthorized use of equipment
	Fraudulent copying of software
	Use of counterfeit or copied software
	Corruption of data
	Illegal processing of data
Compromise of functions	Abuse of rights
	Forging of rights
	Denial of actions
	Breach of personnel availability

© University of Trento, Vrije Universiteit Amsterdam and SESAR Joint Undertaking.

This material can only be used for educational purposes by students enrolled in the class in the heading. All other uses are prohibited.